

USDT0 · SECURITY REVIEW

USDT0 Tether Contracts - PR110 + Upgrade.

A security review of Tether Contracts - PR110 + Upgrade.

CLIENT

USDT0

PROJECT

Tether Contracts -
PR110 + Upgrade

AUDITORS

Roberto Reigada,
Osman Ozdemir

AUDIT WINDOW

August 31 -
September 3, 2026

FINAL REPORT

September 7, 2026

§ 00

Contents.

14 pages - overview, confidence ranking, scope, 5 findings, disclaimer, and about Guardian.

§ 01	Overview	p. 03
§ 02	Confidence Ranking	p. 04
§ 03	Scope & Classifications	p. 05
	Files in Scope	p. 06
§ 04	Findings	p. 07
	Main Review • 5 findings	p. 8-12
§ 05	Disclaimer	p. 13
§ 06	About Guardian	p. 14

Overview.

Guardian reviewed Tether Contracts - PR110 + Upgrade across 2 review rounds. The final report includes 5 Informational findings.

AUDIT FIRM	Guardian	REPOSITORY	Everdawn-Labs/usdt0-tether-contracts-hardhat
CLIENT	USDTO	REVIEWED PR	#110 · 67e1b9c7580dc8eac449cabe3194dcfacbc019c6
PROJECT	Tether Contracts - PR110 + Upgrade	MERGE COMMIT	feeb42dd610e92f44ec85c8cad4157ef27707d00
PREPARED BY	Roberto Reigada, Osman Ozdemir	UPGRADE REVIEW	Celo · 0xD2ab3C9A02DBBAB236BFEC45D1d755DF4267F771
AUDIT WINDOW	August 31 - September 3, 2026		
FINAL REPORT	September 7, 2026		

1.1 Confidence Ranking

5

/5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer's assessment of latent risk. The full scale is on the next page.

1
V. LOW

2
LOW

3
MED

4
HIGH

5
V. HIGH

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACKNOWLEDGED	PARTIALLY RESOLVED	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	0	0	0	0	0
Low	0	0	0	0	0
Informational	5	0	4	0	1

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: Code is highly secure at time of audit. Low risk of latent critical issues.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Only 1 Significant issue was uncovered per week. Design patterns are sound, and test coverage is strong. Recommendation: Suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity issues. Varied Low severity findings.
3 Moderate Confidence	Medium-severity and occasional High-severity issues found. Code is functional, but there are concerning areas such as weak modularity or risky patterns. No critical design flaws were identified, though some patterns could lead to edge-case issues. Recommendation: Address issues thoroughly and consider a targeted follow-up audit depending on code changes.	1-2 High/Critical findings per engagement week.
2 Low Confidence	Code shows frequent emergence of Critical/High vulnerabilities. Audit revealed recurring anti-patterns, weak test coverage, or unclear logic. These characteristics suggest a high likelihood of latent issues. Recommendation: Post-audit development and a second audit cycle are strongly advised.	2-4 High/Critical findings per engagement week, or additional unresolved High/Critical findings uncovered in remediation review.
1 Very Low Confidence	Code has systemic issues. Multiple High/Critical findings (≥ 5 /week), poor security posture, and design flaws that introduce compounding risks. Safety cannot be assured. Recommendation: Halt deployment and seek a comprehensive re-audit after substantial refactoring.	≥ 5 High/Critical findings and overall systemic flaws.

§ 03

Scope & Classifications.

The source review covered six production Solidity files changed by Everdawn Labs PR #110, together with an upgrade assessment of the deployed Celo token proxy. The scoped diff contains 231 additions and 37 deletions.

3.1 Severity Matrix

	IMP · HIGH	IMP · MEDIUM	IMP · LOW	IMPACT · HIGH	Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.
LIK · HIGH	Critical	High	Medium	IMPACT · MEDIUM	Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.
LIK · MED	High	Medium	Low	IMPACT · LOW	Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.
LIK · LOW	Medium	Low	Low	LIKELIHOOD · HIGH	Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.
				LIKELIHOOD · MEDIUM	Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.
				LIKELIHOOD · LOW	Unlikely to ever occur in production.

§ 03

Scope.

The source scope is limited to the six production Solidity files identified below. The deployment scope is the Celo proxy and implementation state.

PR #110 · Source Review

6 SOLIDITY FILES · +231 / -37

```
contracts/Tether/
  WithBlockedList.sol
contracts/Wrappers/
  ArbitrumExtension.sol
  CeloExtension.sol
  CeloOFTEExtension.sol
  OFTEExtension.sol
interfaces/IERC5267.sol
```

Celo · Upgrade Review

ON-CHAIN DEPLOYMENT

```
Celo mainnet token proxy
0xD2ab3C9A02DBBAb236BfEC45D1d755DF4267F771
Token: Tether America USD (USAT)

Implementation at final review
0x49912f84f43d2675d99941b7f21a5d9ed2eab71e

Review focus
Proxy implementation and upgrade state
Celo extension compatibility
Fee-currency settlement behavior
```

§ 04

Findings.

5 Informational findings: 1 Resolved and 4 Acknowledged.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
I-01	Hardcoded Alchemy RPC URL exposes an API key	Informational	INFORMATIONAL	ACKNOWLEDGED	p. 8
I-02	Uncoordinated Arbitrum upgrades stop OFT flows	Compatibility	INFORMATIONAL	ACKNOWLEDGED	p. 9
I-03	Late manifest setup blocks Avalanche upgrade	Configuration	INFORMATIONAL	RESOLVED	p. 10
I-04	Blocking zero address disables minting	Validation	INFORMATIONAL	ACKNOWLEDGED	p. 11
I-05	Blocking the fee reserve stops settlement	Validation	INFORMATIONAL	ACKNOWLEDGED	p. 12

INFORMATIONAL I-01

ACKNOWLEDGED

Hardcoded Alchemy RPC URL exposes an API key.

CATEGORY Informational LOCATION test/0FTExtension.test.js:20

DESCRIPTION

test/0FTExtension.test.js hardcodes an Alchemy RPC URL containing an API key directly and exposes it to everyone who has access to the repository.

RECOMMENDATION

Revoke and rotate the exposed Alchemy API key, and replace the hardcoded RPC URL with an environment variable.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-02

ACKNOWLEDGED

Uncoordinated Arbitrum upgrades stop OFT flows.

CATEGORY Compatibility

LOCATION `contracts/Wrappers/ArbitrumExtension.sol:484-493; contracts/Tether/TetherToken.sol:80-83; usdt0-oft-contracts/deployments/arbitrum-mainnet/solcInputs/c8bf47934980bc87a8dee825db37537e.json:137`

DESCRIPTION

Arbitrum uses independently upgradeable token and OFT proxies. The currently deployed OFT implementation was compiled to invoke the legacy `mint(address,uint256)` and `burn(address,uint256)` token entrypoints. In contrast, the `ArbitrumExtensionV2` implementation on the reviewed branch authorizes the OFT through `crosschainMint(address,uint256)` and `crosschainBurn(address,uint256)`. It does not expose the legacy burn entrypoint and its inherited mint entrypoint is restricted to the token owner.

If only the token proxy is changed to the reviewed implementation, an outgoing OFT `send()` calls the missing legacy burn selector and reverts. An incoming `lzReceive()` calls the inherited mint function as the OFT and reverts because the OFT is not the token owner. Both cross-chain directions remain unavailable until the OFT implementation is also changed to use the IERC-7802 entrypoints.

The current live token and OFT implementations remain compatible. The client has also confirmed that no active Arbitrum upgrade is planned and that a future rollout would upgrade both implementations. This is therefore an operational constraint for a future deployment rather than a vulnerability in the current configuration. An upgrade that changes only one proxy or exposes the intermediate state between separate upgrade transactions will temporarily stop Arbitrum OFT transfers.

RECOMMENDATION

Treat the Arbitrum OFT and token implementations as one compatibility unit. Encode both proxy changes in the same atomic governance transaction so the deployed OFT moves to `crosschainMint` and `crosschainBurn` at the same time as the token implementation.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-03

RESOLVED

Late manifest setup blocks Avalanche upgrade.

CATEGORY Configuration LOCATION scripts/avalanche_usdt0_prepare_upgrade.js:27-28,48-53

DESCRIPTION

The Avalanche preparation script is intended to load `.openzeppelin/usdt0/avalanche.json` before it validates the live proxy and deploys the new implementation. However, the script imports Hardhat before assigning `MANIFEST_DEFAULT_DIR`. Importing Hardhat loads the OpenZeppelin upgrades plugin, whose manifest module reads this environment variable once during module initialization. When the variable is initially unset, the plugin retains the default `.openzeppelin` directory even though `main()` assigns and prints the intended directory afterward.

OpenZeppelin consequently looks for the absent `.openzeppelin/avalanche.json` instead of the checked-in `.openzeppelin/usdt0/avalanche.json` that records the live proxy and implementation. `validateUpgrade` then rejects the live implementation as unregistered. `prepareUpgrade` performs the same validation before deployment, so it stops for the same reason. An operator who follows the standalone command in the script with `MANIFEST_DEFAULT_DIR` unset cannot complete the preparation workflow until they diagnose the failure and export the variable before starting Hardhat. The failure occurs before deployment and does not change on-chain state.

RECOMMENDATION

Assign `MANIFEST_DEFAULT_DIR` before importing Hardhat when the variable is unset. Derive the absolute `.openzeppelin/usdt0` path from `__dirname` so manifest selection does not depend on the operator's working directory.

RESOLUTION

Status: Resolved.

INFORMATIONAL I-04

ACKNOWLEDGED

Blocking zero address disables minting.

CATEGORY Validation LOCATION contracts/Tether/WithBlockedList.sol:29-40,49-52

DESCRIPTION

The blocklist owner can add `address(0)` through either `addToBlockedList` or `addMultipleToBlockedList` because their shared `_addToBlockedList` helper writes every supplied address without validation. ERC20 minting represents newly created tokens as a transfer from `address(0)`. Consequently, every `_mint` call passes that address to `TetherToken._beforeTokenTransfer`, which rejects a blocked sender unless the immediate caller is the token owner.

If the owner blocks `address(0)`, a user call to `WrappedExtension.deposit` transfers the original tokens and then reaches the rejected mint. The revert rolls back the entire transaction, including the original token transfer. A configured OFT contract that is distinct from the token owner also cannot call `crosschainMint` successfully. Deposits and incoming cross-chain mints remain unavailable until the owner removes `address(0)` from the blocklist. Only the owner can trigger this condition and failed calls do not move assets.

RECOMMENDATION

Reject `address(0)` in `_addToBlockedList` before writing `isBlocked`. This applies the same validation to the individual and batch blocklist entrypoints.

RESOLUTION

Status: Acknowledged.

Blocking the fee reserve stops settlement.

CATEGORY Validation

LOCATION `contracts/Tether/WithBlockedList.sol:29-31,37-41,49-52`; `contracts/Tether/TetherToken.sol:47-57`;
`contracts/Wrappers/CeloExtension.sol:23-29,57-79`; `contracts/Wrappers/FeeCurrencyWrapper.sol:101-143`

DESCRIPTION

Celo fee settlement first reserves the maximum gas payment at `GAS_FEE_ADDRESS`. After transaction execution, `creditGasFees` transfers the refund, tip and base fee from that reserve to their recipients. The Celo fee currency interface requires this credit phase to pay every specified amount.

Both `addToBlockedList` and `addMultipleToBlockedList` accept the reserve address. If the token owner blocks it, a later `creditGasFees` call reaches `_beforeTokenTransfer` with `from` set to `GAS_FEE_ADDRESS`. The immediate caller is the configured `FeeCurrencyWrapper` or the Celo VM address, neither of which is the token owner. The inherited hook therefore rejects the blocked sender and reverts the credit as soon as it attempts a transfer.

The revert rolls back every payout in that call. It also prevents `FeeCurrencyWrapper` from clearing `debited` because that write occurs after the external token call. Fee credits remain unavailable until the owner removes the reserve from the blocklist. The owner alone can cause and recover this condition.

RECOMMENDATION

Validate reserved protocol addresses in the shared blocklist write path before updating `isBlocked`. Add an internal validation hook that rejects `GAS_FEE_ADDRESS` in `TetherTokenCeloExtension` so both the single and batch blocklist functions inherit the same restriction.

RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

About Guardian.

Founded in 2022 by DeFi experts, Guardian is a leading audit firm in the DeFi smart contract space. With every audit report, Guardian upholds best-in-class security while achieving our mission to relentlessly secure DeFi.